

RICKROLL.EXE VT SCAN:

Su flareVM ho estratto rickroll.exe.zip, calcolato l'hash SHA-256 e inserito sulla ricerca di VirusTotal. Ecco cosa possiamo estrapolare dai risultati dei sandbox:

INFORMAZIONI SUL MALWARE

Filename: rickroll.exe

SHA256: 48b08ea78124ca010784d9f0faae751fc4a0c72c0e7149ded81fc03819f5d723

Size: 129.99KB

Detection: 43/72 vendors

Family: trojan.badjoke/tedy

Tags: trojan, PUA, hacktool, joke

Architecture: 64-bit PE executable

Filename	MD5	SHA-256	File Size
rickroll.exe.zip	36e846c8bd33a58a66914dc24bc35634	3ac2642e0723cf0b3638994a626aa97fb7041a3b8daf072f1436af7539895b02	42,066

SUMMARY DEL MALWARE:

Nonostante la natura giocosa del malware, si tratta di una classe specifica di trojan chiamata “BadJoke” ovvero un “cattivo scherzo”, ovvero nonostante ispirato ad un “meme” famoso si tratta comunque di un malware che compie azioni dannose sul dispositivo vittima e ha comportamenti maliziosi.

43/72 security vendors flagged this file as malicious

48b08ea78124ca010784d9f0faae751fc4a0c72c0e7149ded81fc03819f5d723

rickroll.exe

Size: 129.99 KB | Last Analysis Date: 2 months ago

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label: trojan.badjoke/tedy

Threat categories: trojan, pua, hacktool

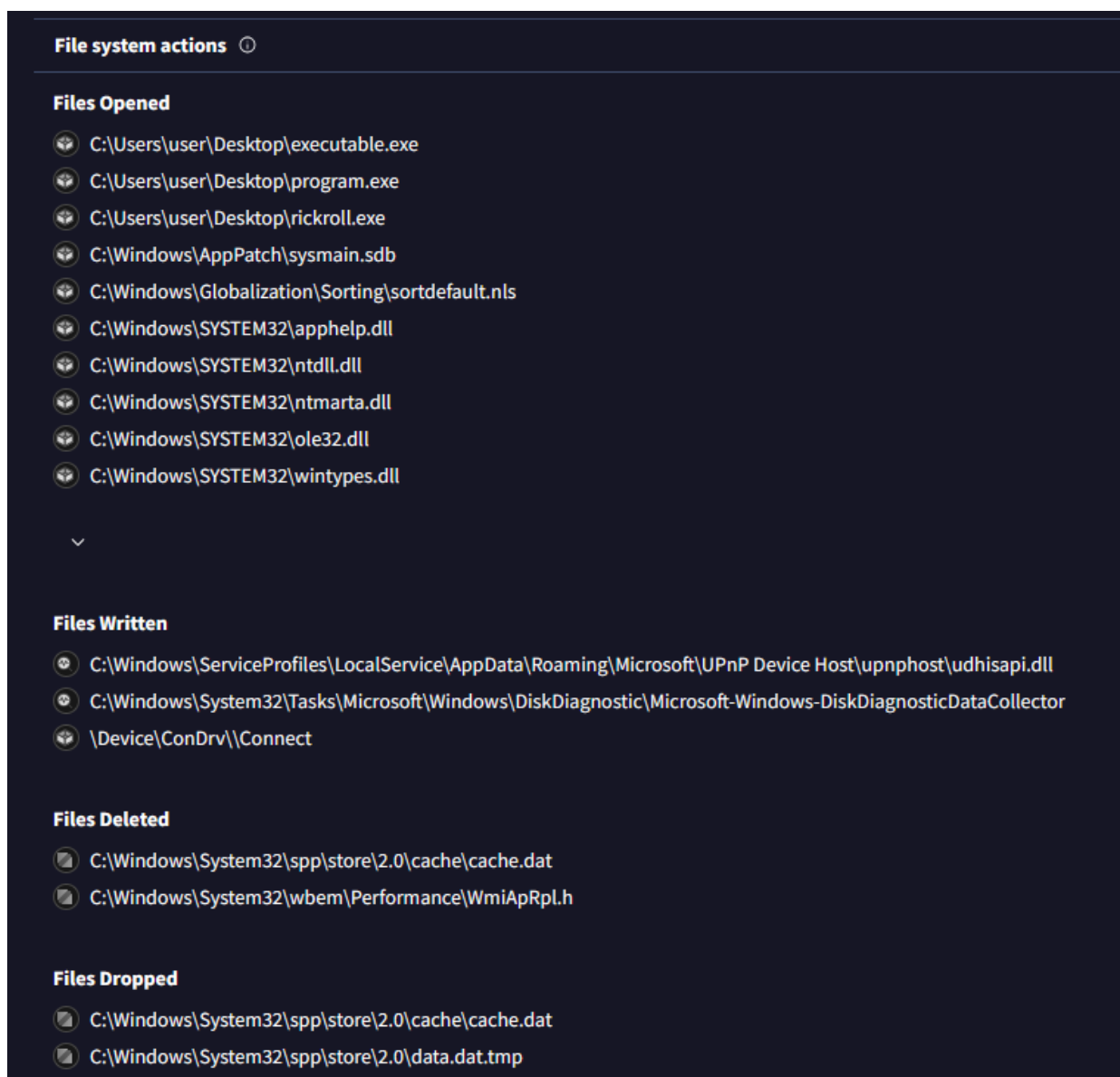
Family labels: badjoke, tedy, joke

Security vendors' analysis

Vendor	Detection
AbnLab-V3	Trojan.Win.Bad.Joke.C5533099
Alibaba	RickWare.Win64.Bad.Joke.872d589b
Alibaba Cloud	SpyWare.Win/Malgent.Gen
ALYac	Gen-Variant.Tedy.723175
Antiy-AVL	HackTool(Hoan)/Win64.Bad.Joke
Arcabit	Trojan.Tedy.D808E7
Arctic Wolf	Unsafe
BitDefender	Gen-Variant.Tedy.723175
Blav Pro	Win64.AIDetectMalware
CrowdStrike Falcon	Win/malicious_confidence_70% (D)
CTX	Ext.trojan.badjoke
DeepInstinct	MALICIOUS
DrWeb	Joke.OpenSite.1
Emsisoft	Gen-Variant.Tedy.723175 (B)
eScan	Gen-Variant.Tedy.723175
GData	Win64.Application.RickRoller.A
Google	Detected
Gridinsoft (no cloud)	Trojan.Win64.Agent.oais1

FILESYSTEM ACTIONS

- 1) Azioni normali: Si legge da solo, e legge le librerie di sistema. Ovvero non sospette, ma in questo step il malware verifica integrità ed estrae il payload.
- 2) File scritti: Scrive sul servizio Universal Plug n Play andando ad annunciarsi su LAN agli altri dispositivi. Scrive qui per manipolare LAN discovery, estrapolare architettura del network e gli end devices, scan (come quello per NetBIOS) e preparare movimento laterale.
Scrive anche su DiskDiagnostic per le scheduled tasks dove modifica task legittime di windows ma non ne crea ancora alcuna, probabilmente per persistenza.
- 3) File cancellati e droppati: cancella i file di SPP cache (software protection platform) e li rimpiazza, bypassando il sistema windows license/activation



NETWORK

- 1) DNS: imposta arc.msn.com (legittimo dominio di microsoft per notizie) per la DNS resolution, fa ciò probabilmente per nascondersi con traffico che a prima vista sembra legittimo traffico di windows sulla quale probabilmente nascondere anche quello del C2 (Command & Control server) come metodo di evasione.
- 2) Traffico IP: Tra le connessioni stabilite possiamo già vedere un ipv4 su porta 443 HTTPS cifrata, molto probabilmente il canale principale per il traffico da C2 in quanto difficile da analizzare. Inoltre un'alta connessione outbound da porta 80 non cifrata che probabilmente invece contiene i dati rubati. Finalmente le connessioni UDP su porta 137 (Standard NETBIOS) nel range IPv4 della LAN della vittima per enumerare gli end devices connessi alla vittima sul network per valutare vettori di attacco sulla rete.
#Nel laboratorio le IPTABLES impostate su gateway kali impediscono questo step droppando ogni richiesta di connessione verso range comuni home network#

Network Communication ⓘ

DNS Resolutions

+  arc.msn.com

IP Traffic

 UDP a83f:8110:cce1:d301:af4:881e:e676:d901:53

 UDP a83f:8110:2a9b:d901:beac:bf78:cce1:d301:53

 UDP a83f:8110:0:0:1400:1400:2800:3800:53

 UDP 192.168.0.71:137

 UDP 192.168.0.29:137

 UDP a83f:8110:45:3bfb:f84:1b02:0:4183:53

 TCP 52.154.209.174:443

 TCP 23.216.81.152:80

 UDP 192.168.0.30:137

 UDP 192.168.0.76:137

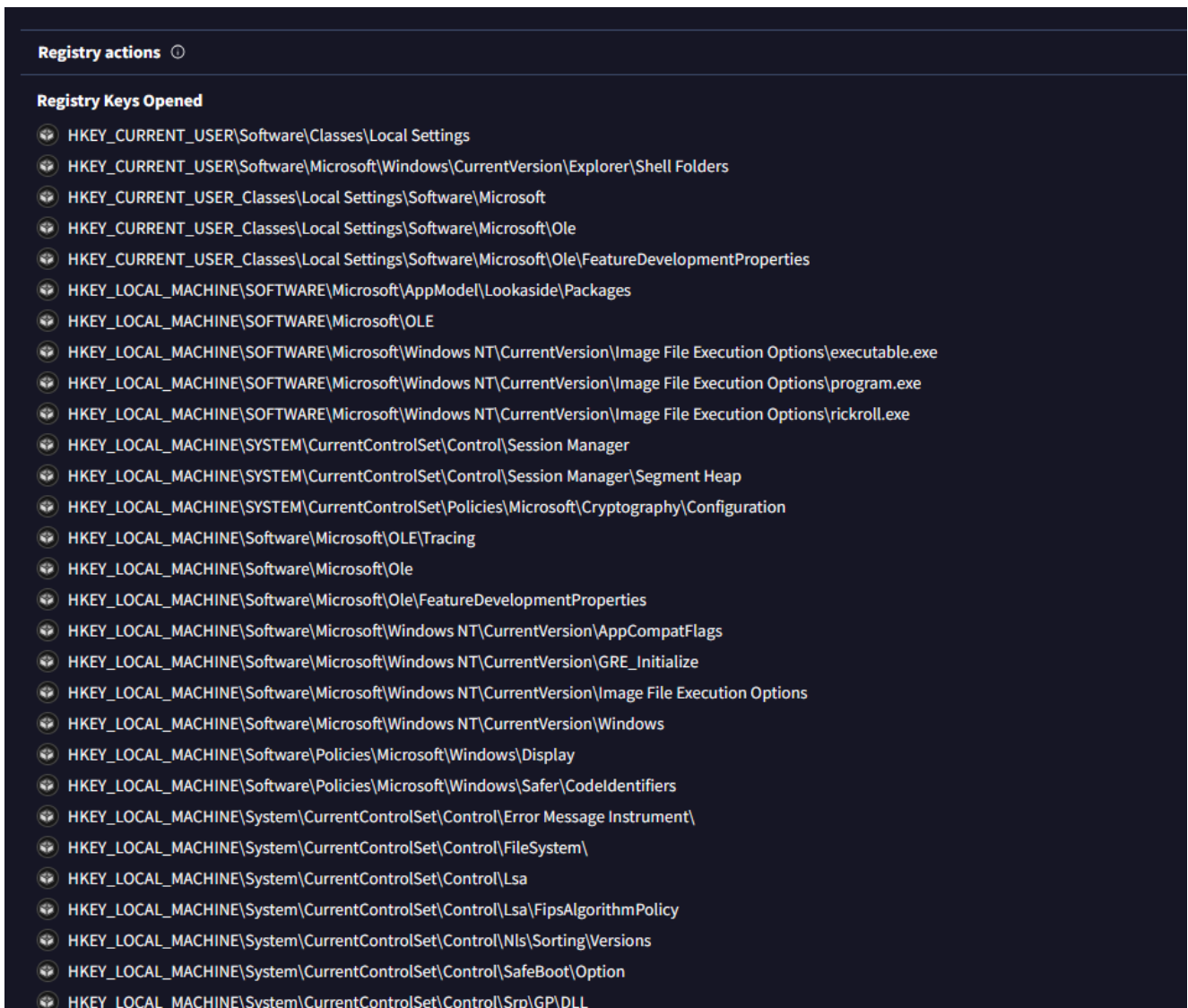
Behavior Similarity Hashes ⓘ

C2AE	7eb58e30b74038daa9b31b5d9df78cf2
CAPA	ead66f0ded3630755f041ac107d944bd
CAPE Sandbox	c9f3dc8655ed9ea9166920d53275d412
Microsoft Sysinternals	b67605e2621ea03a436b9491c0faea2a
VirusTotal Jujubox	5c740c8c47970e581fd486e762b9b846
VirusTotal Observer	d91b8482a5b9b2355cdea11491de3c8c
Zenbox	0197a43f87503f11e3a302afa5971a1f

REGISTRY ACTIONS

Malware svolge una estensiva enumerazione di chiavi su registro. Ma agisce solo su particolari obiettivi:

- 1) Image File Execution Option \rickroll.exe (executable.exe | program.exe): Una feature di debug di windows che il malware assegnando a se stesso e a nomi generici di file executable/program così che qualsiasi programma chiamato in tale modo riesegue il malware. Questa è una tecnica anti-debug dove se si prova a fare debug del malware stesso per analisi invece si riattiva il payload, oppure se si attiva su programmi generici questi vengono hijacked.
- 2) legge chiavi su registry per estrapolare versioni, configurazioni, cifratura, autenticazione per programmare le fasi successive.



PROCESS ACTIONS

- 1) Processi Creati: Si copia su folder world writeable "C:\Users\<USER>\Appdata\Local\Temp" come "executable.exe" (nome generico, IFEO debug hijack lo riattiverebbe) per evasione e moltiplicazione. Vediamo poi su "%SAMPLEPATH%" che il malware si copierebbe come file con filename hash (per evasione) dove si potrebbe riattivare (scheduled tasks, IFEO, altro malware, C2, o qualsiasi cosa possa nel futuro rieseguire questo file)
- 2) Processi terminati: Cancella molte scheduled tasks di Customer Experience Improvement Program per evitare telemetria che potrebbe essere monitorata e riportata ad un team di difesa. Inoltre termina il Windows Error Reporting per evitare analisi automatiche di comportamenti sospetti, crash o instabilità di sistema. Termina il Windows Time Service per poi sincronizzare il sistema con time servers di internet per semplificare le azioni Time-Based del server C2. Manipola il Windows Management Instrumentation, un potente framework amministrativo che permette al malware di fare system recon, eseguire comandi invisibilmente, metodi di persistenza senza registro o per movimento laterale.

Process and service actions

Processes Created

- "C:\Users\<USER>\AppData\Local\Temp\executable.exe"
- %SAMPLEPATH%\48b08ea78124ca010784d9f0faae751fc4a0c72c0e7149ded81fc03819f5d723.exe
- %SAMPLEPATH%\78e07f54eeb6af5191c744ebb8da83dad895eca1.exe

Shell Commands

- "%SAMPLEPATH%\48b08ea78124ca010784d9f0faae751fc4a0c72c0e7149ded81fc03819f5d723.exe"
- "%SAMPLEPATH%\78e07f54eeb6af5191c744ebb8da83dad895eca1.exe"

Processes Terminated

- %CONHOST% "13921835751769188125124624401-224228901394427022-1652302386-665844600-1110543471"
- %CONHOST% "1569098810-2218196701711323596312440757513483848128812950214319441902032801408"
- %windir%\System32\svchost.exe -k WerSvcGroup
- wmiadap.exe /F /T /R
- C:\Windows\System32\conhost.exe
- 2152 - "C:\Program Files\Windows Media Player\wmpnetwk.exe"
- 2760 - C:\Windows\System32\sdclt.exe /CONFIGNOTIFICATION
- 2768 - C:\Windows\system32\sc.exe start w32time task_started
- 2800 - C:\Windows\system32\rundll32.exe dfdts.dll,DfdGetDefaultPolicyAndSMART
- 2812 - taskhost.exe SYSTEM
- 2828 - C:\Windows\system32\schtasks.exe /delete /f /TN "Microsoft\Windows\Customer Experience Improvement Program\Uploader"
- 2832 - C:\Windows\System32\wsqmcons.exe
- 2860 - taskhost.exe \$(Arg0)

MITRE ATT&CK

T1129 – Shared Modules (Execution)

Carica ddl maliziose tramite meccanismi di caricamento moduli legittimi di Windows, inganna l'OS a caricare il proprio codice come se fosse una libreria di sistema reale.

T1055 – Process Injection (Privilege Escalation + Stealth)

Injection di codice malware su altri processi legittimi così da non essere rilevati da Task Manager o AV.

T1497 – Evasione Sandbox/Virtual Machine

Controlla environment per segni di virtualizzazione o sandboxing.

T1056 – Input Capture (keylogging)

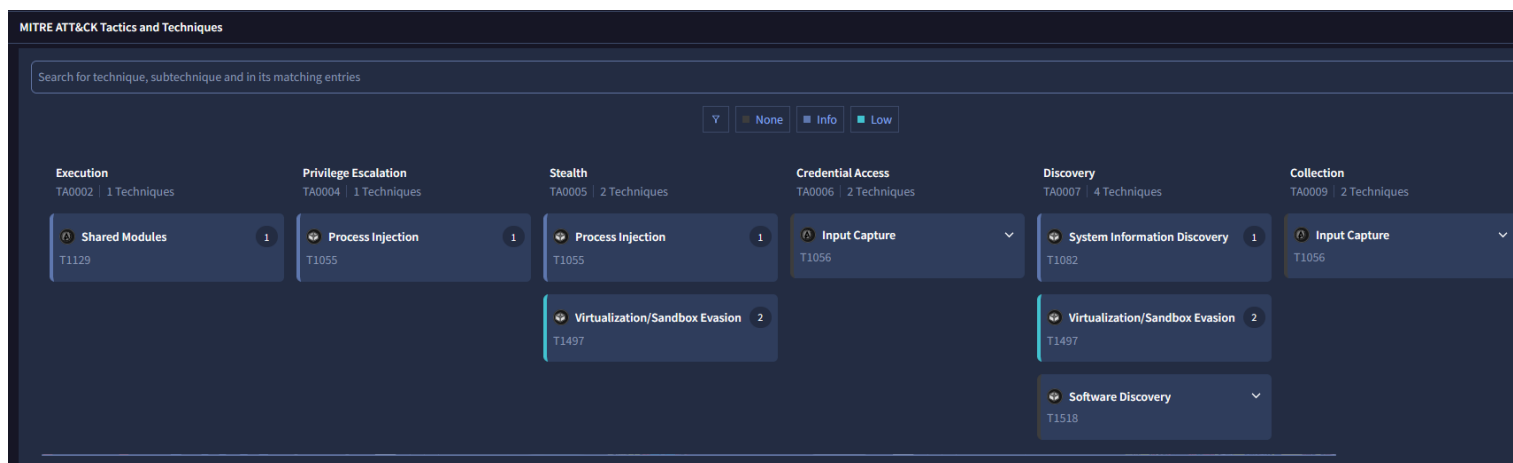
Manda ogni input a C2 periodicamente tramite connessione cifrata

T1082 – SYS Info Discovery

Fingerprinting of the victim's system with OS/hardware/network specs to send to the C2.

T1518 – Software Discovery

Controllo del software su target



MOCK IOC (INDICATOR OF COMPROMISE):

Malware: rickroll.exe / Trojan.Badjoke.Tedy

Date: 29/04/26

HASHES:

SHA-256: 48b08ea78124ca010784d9f0faae751fc4a0c72c0e7149ded81fc03819f5d723

FileSize: 129.99 KB

NETWORK IOCs:

DNS: arc.msn.com (domain fronting)

C2: 52.154.209.174:443 (HTTPS primary)

LAN: 192.168.0.x:137 (NetBIOS recon)

HOST IOCs:

File: %AppData%\Local\Temp\executable.exe

Registry: HKLM\...\Image File Execution Options\rickroll.exe

Registry: HKLM\...\Image File Execution Options\executable.exe

Registry: HKLM\...\Image File Execution Options\program.exe

Process: Kills svchost.exe WerSvcGroup (error reporting)

Task: Deletes CEIP\Uploader scheduled task

DLL: Modified upnphost\udhisapi.dll

MITRE ATT&CK TTPs:

T1055 Process Injection

T1082 System Information Discovery

T1129 Shared Modules

T1497 Virtualization/Sandbox Evasion

T1056 Input Capture

T1518 Software Discovery

